

✓ DEPLOYED & STABILIZED

AI in GRC: Safe Deployment After Critical Failure

From Hallucination to Controlled Automation

Project: GRC AI Assistant

Date: April 2026

The Business Case for AI in GRC

Before AI (Manual Process)

- 🕒 2,400 control tests / quarter (Manual)
- 📅 6 weeks to assess new regulations
- ❗ 15% error rate in evidence submission

The AI Opportunity

- ⚡ Reduce manual review time by 60-70%
- 📈 Scale to 100% control coverage (Continuous)



ROI Positive in 9 Months

First Deployment Failure (Board Summary)

Version 1.0 Approach: Deployed a public LLM (GPT-4) directly against GRC data. No guardrails. No human review.

-  **AI Hallucination:** System invented fake ISO regulations, creating immediate compliance violation risks.
-  **Data Leakage:** Vendor data appeared in public LLM logs, compromising confidentiality and trust.
-  **No Audit Trail:** AI decisions were "black box," making it impossible to pass internal or external audits.
-  **Control Override:** Users bypassed security via simple text prompts, compromising the environment.



CRITICAL ACTION: v1.0 Deployment Halted. Root Cause Analysis Initiated.

The Remediated Architecture



Private AI Model

Runs inside our VPC. No data leaves our perimeter. **Zero data leakage risk.**



Retrieval-Augmented (RAG)

AI must cite actual policy sections from approved sources. **Eliminates hallucinations.**



Human Review Gate

Risk scores require human approval. AI recommends; human decides. **Retains accountability.**



Immutable Audit Trail

Every decision logged with prompt, response, and source. **Ready for any audit.**

Results & ROI Analysis

Metric	Manual / v1.0	v2.0 (Stabilized)
Control Mapping Accuracy	68%	94%
Data Leakage Incidents	3	0
Regulatory Gap Analysis Time	6 Weeks	3 Days
Control Coverage	20% (Sampled)	100% (Continuous)
Audit Readiness	None	Full Traceability

Financial Impact (Annualized):

- + GRC manual hours saved: 1,800 hrs
- + Assessment savings: \$95,000
- + Avoided penalties (est): \$250k+



Board Decision & Next Steps

Decision Requested:

- ✓ **Approve** current deployment as compliant.
- ✓ **Endorse** expansion to Vendor Risk & Regulatory Change Monitoring (Q3-Q4 2026).

Ongoing Oversight:

We will report quarterly on:

- Accuracy metrics (Target >90%)
- Human review rate (Target <20%)
- Zero data leakage incidents



AI provides the engine; humans provide the steering.

Image Sources



https://static.vecteezy.com/system/resources/previews/043/344/346/non_2x/abstract-clean-blue-white-business-technology-background-vector.jpg

Source: www.vecteezy.com



<https://www.cio.com/wp-content/uploads/2025/08/4046967-0-02094400-1756381523-Overlay-dashboard-or-trader-with-stress-headache-or-burnout-from-trading-data-bad-in-vestment-or-stocks.-Anxiety-debt-or-frustrated-man-with-digital-ui-or-ux-on-financial-loss-on-screen-at-night.jpg?quality=50&strip=all&w=1024>

Source: www.cio.com



https://img.freepik.com/premium-vector/broken-shield-symbol-red-prohibition-circle-security-breach-warning-protection-alert_797523-4907.jpg

Source: www.freepik.com



https://static.vecteezy.com/system/resources/previews/047/783/127/non_2x/illustration-of-a-secure-cloud-server-infrastructure-with-data-security-and-protection-features-including-multiple-servers-a-cloud-icon-security-shields-and-data-protection-elements-free-vector.jpg

Source: www.vecteezy.com



https://static.vecteezy.com/system/resources/previews/069/340/793/non_2x/upward-growth-bar-chart-with-green-arrow-business-success-statistics-financial-increase-data-graph-icon-economic-performance-stock-market-trend-vector.jpg

Source: www.vecteezy.com



https://png.pngtree.com/thumb_back/fw800/background/20260123/pngtree-professional-business-meeting-space-with-large-windows-overlooking-in-soft-daylight-image_21205572.webp

Source: pngtree.com